

Docker CIS Compliance Report

Generated on 2026-04-30 10:46:34

Compliance Score	57%
Checks Passed	31 / 54
Status	PASS: 31 FAIL: 23 WARN: 4 N/A: 11
Failures by Severity	CRITICAL: 4 HIGH: 10 MEDIUM: 4 LOW: 5

Host Configuration (0/2 passed)

Control	Severity	Status	Description	Details
1.2.1	HIGH	FAIL	Ensure auditing is configured for the Docker daemon	Windows Audit Policy for Detailed Tracking is not fully configured.
1.1.2	HIGH	MANUAL REVIEW	Ensure only trusted users are allowed to control Docker daemon	Users in docker group: HP

Remediation for 1.2.1:
Linux: Add audit rules for Docker daemon:
sudo auditctl -w /usr/bin/dockerd -k docker
sudo auditctl -w /etc/docker -k docker
Windows: Enable Detailed Tracking via:
auditpol /set /category:"Detailed Tracking" /success:enable /failure:enable
Ref: CIS Docker Benchmark v1.6.0, Section 1.2.1

Daemon Configuration (1/4 passed)

Control	Severity	Status	Description	Details
2.4	HIGH	FAIL	Ensure insecure registries are not used	Insecure registries configured: ::1/128
Daemon_Status	CRITICAL	PASS	Ensure Docker daemon is running	Docker daemon is active and reachable

Control	Severity	Status	Description	Details
2.11	MEDIUM	FAIL	Ensure centralized and remote logging is configured	Current logging driver: json-file
2.6	CRITICAL	MANUAL REVIEW	Ensure TLS authentication for Docker daemon is configured	TLS flags not in process args. Check daemon.json manually.

Remediation for 2.4:

Remove insecure registries from /etc/docker/daemon.json:
 Remove the "insecure-registries" key or set it to an empty list:
 {"insecure-registries": []}
 Then restart Docker: `sudo systemctl restart docker`
Ref: CIS Docker Benchmark v1.6.0, Section 2.4

Remediation for 2.11:

Configure a remote logging driver in /etc/docker/daemon.json:
 {"log-driver": "syslog", "log-opts": {"syslog-address": "tcp://your-log-server:514"}}
 Other options: splunk, gelf, fluentd, awslogs
 Then restart Docker: `sudo systemctl restart docker`
Ref: CIS Docker Benchmark v1.6.0, Section 2.11

Socket Configuration (0/4 passed)

Control	Severity	Status	Description	Details
3.15	HIGH	N/A	Ensure that the Docker socket file ownership is set to root:docker	Socket not found
3.16	HIGH	N/A	Ensure that the Docker socket file permissions are set to 660 or more restrictively	Socket not found
3.3	MEDIUM	N/A	Ensure that docker.socket file ownership is set to root:root	File not found
3.4	MEDIUM	N/A	Ensure that docker.socket file permissions are set to 644 or more restrictive	File not found

Container Runtime (0/7 passed)

Control	Severity	Status	Description	Details
5.32	CRITICAL	FAIL	Ensure that the Docker socket is not mounted inside any containers	Containers mounting docker.sock: cis_test_vulnerable
5.10	CRITICAL	FAIL	Ensure that the host's network namespace is not shared	Containers using host network: cis_test_vulnerable
5.11	HIGH	FAIL	Ensure that the memory usage for containers is limited	Containers without memory limits: cis_test_vulnerable
5.5	CRITICAL	FAIL	Ensure that privileged containers are not used	Privileged containers: cis_test_vulnerable

Control	Severity	Status	Description	Details
4.1	HIGH	FAIL	Ensure that a user for the container has been created (Non-root)	Running as root: cis_test_vulnerable
5.13	MEDIUM	FAIL	Ensure that the container's root filesystem is mounted as read only	Containers with writable rootfs: cis_test_vulnerable
5.6	CRITICAL	FAIL	Ensure sensitive host system directories are not mounted	Violations: {'cis_test_vulnerable': ['/']}

Remediation for 5.32:

Do NOT mount the Docker socket inside containers:
 Remove `-v /var/run/docker.sock:/var/run/docker.sock` from your docker run command.
 If you need Docker API access, use a restricted proxy like docker-socket-proxy:
`docker run -v /var/run/docker.sock:/var/run/docker.sock tecnativa/docker-socket-proxy`
Ref: CIS Docker Benchmark v1.6.0, Section 5.32

Remediation for 5.10:

Do NOT use `--network=host`. Use bridge (default) or custom networks:
`docker run --network=bridge`
 Or create a custom network:
`docker network create mynet`
`docker run --network=mynet`
Ref: CIS Docker Benchmark v1.6.0, Section 5.10

Remediation for 5.11:

Set memory limits when running containers:
`docker run --memory=512m --memory-swap=1g`
 In docker-compose.yml:
 deploy:
 resources:
 limits:
 memory: 512M
Ref: CIS Docker Benchmark v1.6.0, Section 5.11

Remediation for 5.5:

Do NOT use the `--privileged` flag. Instead, grant only specific capabilities:
`docker run --cap-drop ALL --cap-add NET_BIND_SERVICE`
 If a container currently uses `--privileged`, re-create it without that flag:
`docker stop && docker rm`
`docker run --cap-drop ALL --cap-add`
Ref: CIS Docker Benchmark v1.6.0, Section 5.5

Remediation for 4.1:

Always specify a non-root user in your Dockerfile:
`RUN useradd -r appuser`
`USER appuser`
 Or pass `--user` at runtime:
`docker run --user 1000:1000`
Ref: CIS Docker Benchmark v1.6.0, Section 4.1

Remediation for 5.13:

Run containers with a read-only root filesystem:
`docker run --read-only`
 Use tmpfs for writable directories:
`docker run --read-only --tmpfs /tmp --tmpfs /run`
Ref: CIS Docker Benchmark v1.6.0, Section 5.13

Remediation for 5.6:

Do NOT mount sensitive host directories. Remove volume mounts for:
`/`, `/boot`, `/dev`, `/etc`, `/lib`, `/proc`, `/sys`, `/usr`
 Use named volumes instead of host bind mounts:

```
docker volume create app-data
docker run -v app-data:/app/data
Ref: CIS Docker Benchmark v1.6.0, Section 5.6
```

Image Security (2/6 passed)

Control	Severity	Status	Description	Details
IMG-03	HIGH	FAIL	Ensure Content Trust for Docker is enabled	DOCKER_CONTENT_TRUST is not set. Image pulls are not signature-verified.
IMG-04	LOW	PASS	Ensure there are no dangling images	No dangling images found.
IMG-05	LOW	PASS	Ensure Docker images are not excessively large	All images are under 1.00 GB.
IMG-01	MEDIUM	FAIL	Ensure images are not tagged with 'latest'	Images using latest/untagged: test_env-vulnerable-app:latest, test_env-secure-app:latest, project-3_team_34-service:latest, postgres:latest, nginx:latest, alpine:latest
IMG-02	MEDIUM	FAIL	Ensure Docker images are not outdated	Stale images (>90d): alpine:latest (92d old)
IMG-06	CRITICAL	N/A	Ensure Docker images are scanned for vulnerabilities	Scanner execution failed for 'test_env-vulnerable-app:latest'. Ensure Docker Scout or Trivy is properly configured.

Remediation for IMG-03:

```
Enable Docker Content Trust:
export DOCKER_CONTENT_TRUST=1
To make it permanent, add to your shell profile (~/.bashrc or ~/.profile):
echo 'export DOCKER_CONTENT_TRUST=1' >> ~/.bashrc
Windows PowerShell:
[System.Environment]::SetEnvironmentVariable('DOCKER_CONTENT_TRUST','1','User')
Ref: CIS Docker Benchmark v1.6.0, Section 4.5
```

Remediation for IMG-01:

```
Always use specific version tags instead of :latest:
docker pull nginx:1.25.3 (instead of docker pull nginx:latest)
In Dockerfile:
FROM python:3.12-slim (instead of FROM python:latest)
Re-tag existing images:
docker tag myapp:latest myapp:1.0.0
Ref: CIS Docker Benchmark v1.6.0, Section 4.7
```

Remediation for IMG-02:

```
Rebuild images from updated base images regularly:
docker pull :
docker build --no-cache -t myapp:latest .
Set up a CI/CD pipeline to rebuild images on a schedule (e.g., weekly).
Ref: Docker Security Best Practices – Image Freshness
```

Dockerfile Security (28/48 passed)

Control	Severity	Status	Description	Details
DL-03	LOW	WARN	Ensure ADD is not used for remote URLs	[Image 25109184c71b] ADD instructions found (use COPY for local files, curl/wget for remote): Line 1: ADD used instead of COPY
DL-05	LOW	PASS	Ensure apt-get uses --no-install-recommends	[Image 25109184c71b] No RUN instructions found.
DL-04	HIGH	PASS	Ensure SSH port 22 is not exposed	[Image 25109184c71b] No EXPOSE instructions found.
DL-01	MEDIUM	N/A	Ensure FROM does not use :latest tag	[Image 25109184c71b] FROM instructions are not preserved in image history. See Image Security checks (IMG-01) for tag validation.
DL-06	LOW	FAIL	Ensure HEALTHCHECK instructions have been added to container images	[Image 25109184c71b] No HEALTHCHECK instruction found.
DL-02	HIGH	FAIL	Ensure a non-root USER is specified	[Image 25109184c71b] No USER instruction found. Container will run as root by default.
DL-08	CRITICAL	PASS	Ensure secrets are not stored in Dockerfile ENV instructions	[Image 25109184c71b] No ENV instructions found.
DL-07	MEDIUM	PASS	Ensure update instructions are not used alone	[Image 25109184c71b] No RUN instructions found.
DL-03	LOW	PASS	Ensure ADD is not used for remote URLs	[Image 8b067d24af1b] No ADD instructions found. COPY is used correctly.
DL-05	LOW	PASS	Ensure apt-get uses --no-install-recommends	[Image 8b067d24af1b] No apt-get install commands found.
DL-04	HIGH	PASS	Ensure SSH port 22 is not exposed	[Image 8b067d24af1b] No EXPOSE instructions found.
DL-01	MEDIUM	N/A	Ensure FROM does not use :latest tag	[Image 8b067d24af1b] FROM instructions are not preserved in image history. See Image Security checks (IMG-01) for tag validation.
DL-06	LOW	PASS	Ensure HEALTHCHECK instructions have been added to container images	[Image 8b067d24af1b] HEALTHCHECK instruction found (line 6).
DL-02	HIGH	PASS	Ensure a non-root USER is specified	[Image 8b067d24af1b] Non-root USER 'appuser' is set (line 8).
DL-08	CRITICAL	PASS	Ensure secrets are not stored in Dockerfile ENV instructions	[Image 8b067d24af1b] No ENV instructions found.
DL-07	MEDIUM	PASS	Ensure update instructions are not used alone	[Image 8b067d24af1b] No isolated update instructions found.
DL-03	LOW	WARN	Ensure ADD is not used for remote URLs	[Image 3a44c13c4be3] ADD instructions found (use COPY for local files, curl/wget for remote): Line 15: ADD used instead of COPY
DL-05	LOW	PASS	Ensure apt-get uses --no-install-recommends	[Image 3a44c13c4be3] All apt-get install commands use --no-install-recommends.

Control	Severity	Status	Description	Details
DL-04	HIGH	PASS	Ensure SSH port 22 is not exposed	[Image 3a44c13c4be3] Port 22 is not exposed.
DL-01	MEDIUM	N/A	Ensure FROM does not use :latest tag	[Image 3a44c13c4be3] FROM instructions are not preserved in image history. See Image Security checks (IMG-01) for tag validation.
DL-06	LOW	FAIL	Ensure HEALTHCHECK instructions have been added to container images	[Image 3a44c13c4be3] No HEALTHCHECK instruction found.
DL-02	HIGH	FAIL	Ensure a non-root USER is specified	[Image 3a44c13c4be3] No USER instruction found. Container will run as root by default.
DL-08	CRITICAL	PASS	Ensure secrets are not stored in Dockerfile ENV instructions	[Image 3a44c13c4be3] No ENV instructions found.
DL-07	MEDIUM	PASS	Ensure update instructions are not used alone	[Image 3a44c13c4be3] No isolated update instructions found.
DL-03	LOW	PASS	Ensure ADD is not used for remote URLs	[Image 78481659c47e] No ADD instructions found. COPY is used correctly.
DL-05	LOW	PASS	Ensure apt-get uses --no-install-recommends	[Image 78481659c47e] All apt-get install commands use --no-install-recommends.
DL-04	HIGH	PASS	Ensure SSH port 22 is not exposed	[Image 78481659c47e] Port 22 is not exposed.
DL-01	MEDIUM	N/A	Ensure FROM does not use :latest tag	[Image 78481659c47e] FROM instructions are not preserved in image history. See Image Security checks (IMG-01) for tag validation.
DL-06	LOW	FAIL	Ensure HEALTHCHECK instructions have been added to container images	[Image 78481659c47e] No HEALTHCHECK instruction found.
DL-02	HIGH	FAIL	Ensure a non-root USER is specified	[Image 78481659c47e] No USER instruction found. Container will run as root by default.
DL-08	CRITICAL	PASS	Ensure secrets are not stored in Dockerfile ENV instructions	[Image 78481659c47e] No secrets found in ENV instructions.
DL-07	MEDIUM	PASS	Ensure update instructions are not used alone	[Image 78481659c47e] No isolated update instructions found.
DL-03	LOW	PASS	Ensure ADD is not used for remote URLs	[Image 6e23479198b9] No ADD instructions found. COPY is used correctly.
DL-05	LOW	PASS	Ensure apt-get uses --no-install-recommends	[Image 6e23479198b9] All apt-get install commands use --no-install-recommends.
DL-04	HIGH	PASS	Ensure SSH port 22 is not exposed	[Image 6e23479198b9] Port 22 is not exposed.
DL-01	MEDIUM	N/A	Ensure FROM does not use :latest tag	[Image 6e23479198b9] FROM instructions are not preserved in image history. See Image Security checks (IMG-01) for tag validation.

Control	Severity	Status	Description	Details
DL-06	LOW	FAIL	Ensure HEALTHCHECK instructions have been added to container images	[Image 6e23479198b9] No HEALTHCHECK instruction found.
DL-02	HIGH	FAIL	Ensure a non-root USER is specified	[Image 6e23479198b9] No USER instruction found. Container will run as root by default.
DL-08	CRITICAL	PASS	Ensure secrets are not stored in Dockerfile ENV instructions	[Image 6e23479198b9] No secrets found in ENV instructions.
DL-07	MEDIUM	PASS	Ensure update instructions are not used alone	[Image 6e23479198b9] No isolated update instructions found.
DL-03	LOW	WARN	Ensure ADD is not used for remote URLs	[Image 65d273bce1f7] ADD instructions found (use COPY for local files, curl/wget for remote): Line 3: ADD used instead of COPY
DL-05	LOW	PASS	Ensure apt-get uses --no-install-recommends	[Image 65d273bce1f7] No apt-get install commands found.
DL-04	HIGH	PASS	Ensure SSH port 22 is not exposed	[Image 65d273bce1f7] Port 22 is not exposed.
DL-01	MEDIUM	N/A	Ensure FROM does not use :latest tag	[Image 65d273bce1f7] FROM instructions are not preserved in image history. See Image Security checks (IMG-01) for tag validation.
DL-06	LOW	FAIL	Ensure HEALTHCHECK instructions have been added to container images	[Image 65d273bce1f7] No HEALTHCHECK instruction found.
DL-02	HIGH	FAIL	Ensure a non-root USER is specified	[Image 65d273bce1f7] No USER instruction found. Container will run as root by default.
DL-08	CRITICAL	PASS	Ensure secrets are not stored in Dockerfile ENV instructions	[Image 65d273bce1f7] No secrets found in ENV instructions.
DL-07	MEDIUM	WARN	Ensure update instructions are not used alone	[Image 65d273bce1f7] Isolated update commands found: Line 5: apk update used without add/upgrade

Remediation for DL-03:

Use COPY instead of ADD unless you specifically need to extract a tar file.
 For downloading remote files, use curl or wget inside a RUN instruction:
 RUN curl -fsSL https://example.com/file.tar.gz | tar -xz
 Ref: CIS Docker Benchmark v1.6.0, Section 4.9

Remediation for DL-06:

Add a HEALTHCHECK instruction to your Dockerfile:
 HEALTHCHECK --interval=5m --timeout=3s \\
 CMD curl -f http://localhost/ || exit 1
 Ref: CIS Docker Benchmark v1.6.0, Section 4.6

Remediation for DL-02:

Add a USER instruction to your Dockerfile to run as a non-root user:
 RUN groupadd -r appuser && useradd -r -g appuser appuser
 USER appuser
 Ref: CIS Docker Benchmark v1.6.0, Section 4.1

Remediation for DL-03:

Use COPY instead of ADD unless you specifically need to extract a tar file.

For downloading remote files, use curl or wget inside a RUN instruction:
RUN curl -fsSL https://example.com/file.tar.gz | tar -xz
Ref: CIS Docker Benchmark v1.6.0, Section 4.9

Remediation for DL-06:

Add a HEALTHCHECK instruction to your Dockerfile:
HEALTHCHECK --interval=5m --timeout=3s \\
CMD curl -f http://localhost/ || exit 1
Ref: CIS Docker Benchmark v1.6.0, Section 4.6

Remediation for DL-02:

Add a USER instruction to your Dockerfile to run as a non-root user:
RUN groupadd -r appuser && useradd -r -g appuser appuser
USER appuser
Ref: CIS Docker Benchmark v1.6.0, Section 4.1

Remediation for DL-06:

Add a HEALTHCHECK instruction to your Dockerfile:
HEALTHCHECK --interval=5m --timeout=3s \\
CMD curl -f http://localhost/ || exit 1
Ref: CIS Docker Benchmark v1.6.0, Section 4.6

Remediation for DL-02:

Add a USER instruction to your Dockerfile to run as a non-root user:
RUN groupadd -r appuser && useradd -r -g appuser appuser
USER appuser
Ref: CIS Docker Benchmark v1.6.0, Section 4.1

Remediation for DL-06:

Add a HEALTHCHECK instruction to your Dockerfile:
HEALTHCHECK --interval=5m --timeout=3s \\
CMD curl -f http://localhost/ || exit 1
Ref: CIS Docker Benchmark v1.6.0, Section 4.6

Remediation for DL-02:

Add a USER instruction to your Dockerfile to run as a non-root user:
RUN groupadd -r appuser && useradd -r -g appuser appuser
USER appuser
Ref: CIS Docker Benchmark v1.6.0, Section 4.1

Remediation for DL-03:

Use COPY instead of ADD unless you specifically need to extract a tar file.
For downloading remote files, use curl or wget inside a RUN instruction:
RUN curl -fsSL https://example.com/file.tar.gz | tar -xz
Ref: CIS Docker Benchmark v1.6.0, Section 4.9

Remediation for DL-06:

Add a HEALTHCHECK instruction to your Dockerfile:
HEALTHCHECK --interval=5m --timeout=3s \\
CMD curl -f http://localhost/ || exit 1
Ref: CIS Docker Benchmark v1.6.0, Section 4.6

Remediation for DL-02:

Add a USER instruction to your Dockerfile to run as a non-root user:
RUN groupadd -r appuser && useradd -r -g appuser appuser
USER appuser
Ref: CIS Docker Benchmark v1.6.0, Section 4.1

Remediation for DL-07:

Combine apt-get update and apt-get install into a single RUN instruction:
RUN apt-get update && apt-get install -y
Ref: CIS Docker Benchmark v1.6.0, Section 4.7

